

Lightwork – Security & Trust Questionnaire (CAIQ-lite)

Lightwork, by Daybreak Labs — pre-answered security assessment for your review team. Structured after the CSA Consensus Assessments Initiative Questionnaire (CAIQ) / Cloud Controls Matrix domains.

Contact: info@daybreakailabs.com · daybreakailabs.com

Read this first (honest posture)

- **Stage:** Lightwork is in **private alpha**. This document is **control coverage**, not a legal attestation or completed certification.
- **No certification is claimed.** We have **no completed SOC 2 / ISO 27001** today; we present control-to-mechanism mapping and can share our security overview and current SOC 2 readiness on request.
- **Deployment model matters.** Lightwork **self-hosts in your environment** (your VPC, on-prem, or air-gapped). Most controls below are enforced by **software you run**, not a service we operate — so *you* hold the data, keys, and network boundary.
- **"Enterprise mode" vs. default.** A bare developer install favors convenience and **fails open** on some paths. The hardened guarantees (egress lock, capability enforcement, dual-control, KMS) bind when you enable **Enterprise mode** / a **compliance profile** (e.g. `[compliance] profiles=['hipaa']`) — which is the supported posture for regulated production. Items below are flagged accordingly.

Response legend: Yes Yes (implemented) · Config Configurable / Enterprise-mode · Partial Partial · Roadmap Roadmap · N/A N/A · On req On request

1. Governance, Risk & Compliance (GRC)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
1.1	Is there a policy engine that governs agent actions?	Yes	Every tool call clears a strictest-wins chokepoint: capability → policy (ALLOW / DENY / REQUIRE_HUMAN) → shield → budget → signed audit, before it executes.
1.2	Are high-risk / dollar-value actions gated for human approval?	Yes	Amount-tier authority gate (e.g. deny wires > threshold; require-human above a dollar limit), plus EU AI Act Art-14 human-oversight holds. Demonstrable via the golden-path run.
1.3	Are prohibited uses enforced and non-overridable?	Yes	Always-on hard-refusal floor rendered into every specialist pack (<code>domain_refusals</code>); no human-override path.
1.4	Is there documented control-to-framework mapping?	Config	<code>maverick compliance</code> maps live controls to EU AI Act, GDPR, NIST AI RMF, Colorado AI Act, NYC LL144, EEOC, CCPA/CPRA. Coverage report, not a legal attestation.

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
1.5	Are governance guarantees tested, not just asserted?	Yes	Roster-wide invariant suite verifies six load-bearing invariants across all 2,020 specialist packs, fault-injected with a non-vacuity control. <code>maverick domains-lint / domains-audit</code> .

2. Identity & Access Management (IAM)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
2.1	Is SSO / OIDC supported?	Config	OpenID-Connect ID-token (JWT) verification against a configured issuer for <code>maverick serve (oidc.py)</code> ; a verified SSO user maps to a least-privilege principal.
2.2	Is role-based access control enforced?	Config	RBAC with per-role tool allow/deny and max-risk ceilings; global / channel / user ACLs; fail-closed on config error.
2.3	Is least privilege enforced for agents (not just users)?	Yes	Attenuate-only capability tokens: a sub-agent can only narrow its parent's rights, never widen — enforced at every spawn and tool call.
2.4	Are per-action / short-lived credentials supported?	Config	Per-call capability tokens: a broad run-grant is exchanged for a single-tool, single-use, ~30s signed token per call (<code>tool_token</code> ; <code>[capabilities] per_call_tokens</code>).
2.5	Is separation of duties enforced on approvals?	Yes	Dual control: the principal who initiates an action can never be the one who approves it (N-of-M).
2.6	Is there an emergency stop / kill switch?	Yes	File, in-process, and cluster-wide kill switch checked at every tool boundary (<code>maverick halt</code>).

3. Data Security & Encryption (DSP / EKM)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
3.1	Is data encrypted at rest?	Yes	AES-256-GCM envelope encryption of memory + world-model content (<code>tenant/kms.py</code>); on by default.
3.2	Is customer-managed / BYOK key management supported?	Config	Cloud KMS BYOK — AWS KMS, GCP KMS, HashiCorp Vault transit. The KEK stays in the customer HSM; fail-closed (no silent downgrade to local keys).
3.3	Is data encrypted in transit?	Yes	Standard TLS for all network surfaces; self-hosted, so transit stays inside your boundary.
3.4	Is tenant data isolated in multi-tenant deployments?	Config	Per-tenant Data Encryption Keys + Postgres row-level security; one tenant's key can never open another's.
3.5	Can the agent's outbound data paths be locked down?	Config	Enterprise-mode egress lock blocks the agent's outbound paths (model calls + HTTP tools) at the gate, so a prompt-injected agent can't exfiltrate through them. Pair with a network egress firewall for raw-shell paths.

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
3.6	Is sensitive data redacted in logs / telemetry?	Yes	Secret/PII redaction at ingest and in support bundles (<code>privacy.py</code>); no required external telemetry.

4. Logging, Monitoring & Audit (LOG)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
4.1	Is there an immutable, tamper-evident audit trail?	Yes	Append-only, Ed25519-signed, hash-chained Operating Record; altering any row breaks the chain. On by default.
4.2	Can the audit log be verified independently / offline?	Yes	<code>maverick audit verify --pubkey <externally-held key></code> walks signatures + hash chain with no network. (Verified in the golden-path demo: chain intact; a tampered amount is caught as <code>bad_hash</code> .)
4.3	Is whole-file deletion / truncation detectable?	Yes	Cross-file tip anchors detect removal/truncation of an entire day-file, not just row edits.
4.4	Can the signing key be custodied off-host / in a KMS?	Config	Signing key can be held off-host / KMS-wrapped (<code>MAVERICK_AUDIT_SIGNING_KEY[_WRAPPED]</code>) to defend against a privileged local attacker re-signing history.
4.5	Can audit data be exported to a SIEM?	Yes	<code>maverick audit export</code> (JSONL / ArcSight CEF) and <code>audit forward</code> to a SIEM collector (Splunk / Sentinel / QRadar).

5. Application & Agent Security (AIS)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
5.1	Is there defense against prompt injection / jailbreaks?	Config	Agent Shield screens input, tool calls, and output at three sinks, with a decode pre-pass that re-scans de-obfuscated variants. Detector strength depends on the configured backend (built-in rules vs. full shield).
5.2	Are runaway / cost-exhaustion loops bounded?	Yes	Hard budget caps on dollars, wall-clock, input/output tokens, and tool calls — enforced atomically at record time. (Golden-path: a runaway loop is CAPPED.)
5.3	Is model-generated code sandboxed?	Config	Pluggable sandboxes (local subprocess, Docker, gVisor, Podman, devcontainer, Kubernetes, Firecracker, SSH, Modal); network-off by default.
5.4	Is there a default-deny posture for tools / network?	Config	Tool allow-lists per pack; sandbox network denied by default; egress lock in Enterprise mode.
5.5	Is provider/API rate-limiting handled safely?	Yes	Reactive rate limiter plus a predictor; retries with backoff on provider rate-limit/connection errors.
5.6	Can you run without any third-party model provider?	Config	Local/self-hosted models supported (Ollama, vLLM, TGI) for fully offline operation.

6. Infrastructure, Isolation & Deployment (IVS)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
6.1	Can it be fully self-hosted with no required egress?	Yes	Runs in your VPC, on-prem, or fully air-gapped; no telemetry, no call-home.
6.2	Is there an air-gap readiness check?	Config	<code>maverick airgap check</code> verifies no outbound path before you trust the box. (Config audit, not OS-level enforcement — pair with network controls.)
6.3	Is confidential computing supported?	Partial	SEV-SNP / TDX detection (<code>maverick confidential-compute</code>); detection only, not remote attestation. <code>Roadmap</code> attestation on roadmap.
6.4	Is enterprise hardening verifiable, not just configured?	Config	<code>maverick enterprise verify --require</code> exercises the egress lock and at-rest round-trip rather than reading flags.
6.5	What are the deploy targets?	Yes	Docker, Kubernetes, single VPS, Firecracker microVMs; container image + native installers.

7. Privacy & Data Subject Rights (DSP)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
7.1	Are DSAR / access requests supported?	Config	<code>maverick dsar</code> assembles subject data; <code>maverick erase</code> performs right-to-erasure.
7.2	Are data-retention windows configurable?	Config	Configurable retention (e.g. audit 365d, episodes 90d, events 365d); GDPR Art. 5(1)(e) storage limitation.
7.3	Are ROPA / DPIA artifacts generated?	Config	<code>maverick ropa</code> (Art-30 records of processing), <code>maverick dpia</code> (Art-35), AI-Act self-classification scaffold.
7.4	Is customer data used to train shared/global models?	Yes	No. Each customer's learning stays in their own boundary; no cross-customer pooling, no data network effect. Any federated sharing is opt-in, operator-run, signed, and consolidated-lessons-only.

8. Vulnerability, SDLC & Supply Chain (TVM / STA)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
8.1	Is there automated security gating in CI?	Yes	Secret scanning (detect-secrets), lint, a red-team gate, and the roster-wide governance-invariant + connector fuzzing suites run in CI.
8.2	Are dependencies and config pinned / governed?	Yes	Dependency floors pinned; migration-governance + contract checks gate schema/proto changes; new top-level deps require a config knob.

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
8.3	Is there a documented test suite?	Yes	9,000+ automated tests across Python 3.10–3.12.
8.4	Has a third-party penetration test been performed?	On req	Available to discuss with design partners; Roadmap formal third-party pentest is on the roadmap.
8.5	Is there a responsible-disclosure / security contact?	Yes	info@daybreakai labs.com .

9. Resilience & Change Safety (BCR)

#	QUESTION	RESPONSE	DETAIL / EVIDENCE
9.1	Are changes to the agent's learned behavior reversible?	Yes	Every learned change is snapshotted and one command from rollback; a hindsight engine detects learning regressions before they ship.
9.2	Is there an emergency stop for in-flight work?	Yes	Global kill switch (see 2.6).
9.3	Can you prove the system's guarantees on demand?	Yes	maverick proof-pack emits an Ed25519-signed evidence bundle (governance, reliability, performance, shield) that verifies offline and refuses to fabricate.

Certifications & attestations (current state)

ITEM	STATUS
SOC 2 Type I / ISO 27001	Roadmap Not yet certified — readiness + evidence collector available; share status on request
ISO 27001 / 4200	Roadmap Mapping available; not certified
HIPAA	Config Compliance-mode floor (forces redaction, at-rest encryption, egress lock, audit); not a BAA/attestation
GDPR / CCPA	Config DSAR, erasure, retention, ROPA, DPIA tooling; self-hosted data residency
Third-party pent	Roadmap Roadmap / discuss with design partners

How to verify our claims (don't trust — check)

1. **Run the golden path:** `python -m maverick.golden_path` — drives the real governance/capability/audit/budget code (no model) and emits a signed, verifiable trail.
2. **Verify the chain offline:** `maverick audit verify --pubkey <key> .`
3. **Inspect the roster guarantees:** `maverick domains-lint / domains-audit .`
4. **Get the evidence bundle:** `maverick proof-pack .`

Numbers and control states above reflect the current alpha and are subject to change. For your specific questionnaire (SIG, VSA, vendor-specific), send it over — we'll map it control-by-control. info@daybreakai.com .